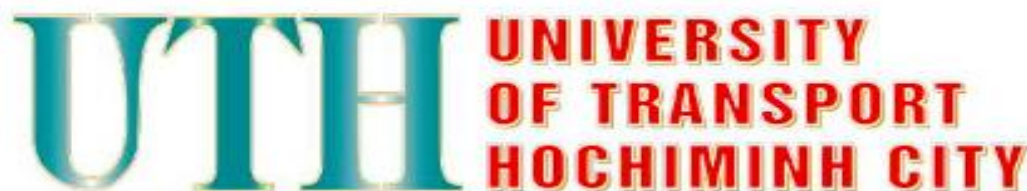


BỘ XÂY DỰNG
TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI TP.HCM
VIỆN ĐÀO TẠO CHẤT LƯỢNG CAO



BÁO CÁO MÔN ĐIỆN TOÁN Đám Mây

ĐỀ TÀI: TRIỂN KHAI HTTPS VÀ BẢO MẬT TRUY CẬP CHO WEBSITE CLOUD

(Implementing HTTPS and Access Security for Cloud Websites)

Giảng viên hướng dẫn: TS Lê Quốc Tuấn

Lớp: 012012303904

SINH VIÊN THỰC HIỆN: Nhóm 20

Nguyễn Lê Huy Tâm: 056206011188

Huỳnh Đình Chấn: 0772006002307

TPHCM – 09/2026

PHÂN CÔNG NHÓM

STT	Họ và Tên	Vai trò	Nhiệm vụ được giao	Mức độ đóng góp
1	Nguyễn Lê Huy Tâm	Nhóm trưởng	Soạn báo cáo; Xây dựng Website hệ thống; Chính cấu hình server, bastion, host cho hệ thống, thiết lập server trên AWS và Demo	100%
2	Huỳnh Đình Chấn	Thành viên	Soạn nội dung lý thuyết; Soạn nội dung thuyết trình và Xây dựng Website hệ thống	100%

LỜI CẢM ƠN

Trong quá trình thực hiện bài tập lớn với đề tài “Triển khai HTTPS và bảo mật truy cập cho Website Cloud”, chúng em đã nhận được sự hướng dẫn, hỗ trợ và giúp đỡ quý báu từ giảng viên.

Trước hết, chúng em xin chân thành cảm ơn TS. Lê Quốc Tuấn – giảng viên phụ trách môn học – đã tận tình giảng dạy, hướng dẫn và truyền đạt cho chúng em những kiến thức quý báu trong suốt quá trình học tập và thực hiện đề tài. Những kiến thức về điện toán đám mây, kiến trúc hệ thống và bảo mật đã giúp chúng em có nền tảng để nghiên cứu, thiết kế và triển khai hệ thống SecureCloud.

Trong quá trình thực hiện đề tài, mặc dù nhóm đã cố gắng hoàn thành báo cáo và hệ thống một cách tốt nhất, nhưng do kiến thức và kinh nghiệm thực tế còn hạn chế nên không thể tránh khỏi những thiếu sót. Chúng em rất mong nhận được những ý kiến đóng góp và nhận xét từ TS. Lê Quốc Tuấn để có thể tiếp tục hoàn thiện kiến thức và nâng cao kỹ năng trong tương lai.

Cuối cùng, chúng em xin chân thành cảm ơn TS. Lê Quốc Tuấn đã dành thời gian tận tình hướng dẫn và đánh giá bài tập lớn của nhóm.

Chúng em xin chân thành cảm ơn!

Sinh viên thực hiện

Nguyễn Lê Huy Tâm: 056206011188

Huỳnh Đình Chấn: 0772006002307

TP. Hồ Chí Minh, tháng 09 năm 2026

DANH MỤC BẢNG BIỂU

Bảng 1 - So sánh các mô hình dịch vụ	5
Bảng 2 - Tổng hợp nguy cơ, rủi ro và biện pháp xử lý	7
Bảng 3 - So sánh mã hóa đối xứng và bất đối xứng.....	8
Bảng 4 - Các loại chứng chỉ số thường gặp.....	8
Bảng 5 - Các thành phần mạng trong hệ thống	10
Bảng 6 - Thiết kế Security Group của hệ thống	11
Bảng 7 - Các bước triển khai hệ thống	13
Bảng 8 - Các security header được cấu hình trên Nginx.....	14
Bảng 9 - Kết quả kiểm thử.....	19
Bảng 10 - Đánh giá theo mục tiêu	20

DANH MỤC HÌNH ẢNH

Hình 1 - Trang index	15
Hình 2 - Trang login	15
Hình 3 - Trang dashboard.....	16
Hình 4 - Not secure URL.....	16
Hình 5 - Đổi URL từ login thành dashboard.....	16
Hình 6 - Đổi URL từ login thành dashboard không thành công	16
Hình 7 - Web server đang hoạt động trên AWS Console	17
Hình 8 – Kết quả Demo 3	17
Hình 9 - Kết quả Demo 4 (Security Group)	18
Hình 10 – Kết quả Demo 5 (Security Headers).....	18
Hình 11 – Kết quả Demo 6 (Log).....	19

MỤC LỤC

MỞ ĐẦU.....	3
1. Mục tiêu của đề tài.....	3
2. Phạm vi và phương pháp	3
3. Phạm vi và đối tượng nghiên cứu.....	4
CHƯƠNG 1. TỔNG QUAN VỀ CLOUD VÀ BẢO MẬT WEBSITE.....	5
1.1. Điện toán đám mây và mô hình dịch vụ	5
1.2. Kiến trúc website trên cloud	5
1.3. Bảo mật thông tin và mô hình CIA	6
1.4. Năm lớp bảo mật SecureCloud.....	6
CHƯƠNG 2. NGUY CƠ VÀ GIẢI PHÁP HTTPS	7
2.1. Nguy cơ của HTTP	7
2.2. Các rủi ro chính	7
2.3. HTTPS và TLS.....	7
2.4. Mã hóa đối xứng và bất đối xứng.....	8
2.4. Chứng chỉ số và AWS Certificate Manager	8
2.5. SSL termination, redirect và HSTS	9
CHƯƠNG 3. KIẾN TRÚC VÀ BẢO MẬT HỆ THỐNG SECURECLOUD	10
3.1. Mô hình trách nhiệm chia sẻ.....	10
3.2. Kiến trúc tổng thể	10
3.3. Thiết kế mạng.....	10
3.4. Security Group và nguyên tắc quyền tối thiểu.....	11
3.5. Bastion Host và Application Load Balancer	11
3.5.1. Bastion Host.....	11
3.5.2. Application Load Balancer (ALP).....	11
3.6. Kiểm soát truy cập ở tầng ứng dụng.....	12
CHƯƠNG 4. TRIỂN KHAI HỆ THỐNG.....	13
4.1. Quy trình triển khai.....	13
4.2. Kiến trúc hệ thống và website.....	13
4.2.1. Kiến trúc hệ thống.....	13
4.2.2. Website SecureCloud.....	14

4.3. Triển khai hạ tầng và web server	14
4.4. Security headers	14
4.5. ALB và thiết kế HTTPS	14
CHƯƠNG 5. KẾT QUẢ DEMO VÀ ĐÁNH GIÁ	15
5.1. Ảnh demo hệ thống	15
5.1.1. UI/UX của hệ thống	15
5.1.2. Bảo mật trang đăng nhập	16
5.1.3. AWS Console	17
5.1.4. Kiểm tra Security Headers và Log	18
5.2. Kết quả kiểm thử	19
5.3. Đánh giá theo mục tiêu	20
5.4. Ưu điểm	20
5.5. Hạn chế	20
5.6. Hướng phát triển và bài học kinh nghiệm	21
KẾT LUẬN	22
TÀI LIỆU THAM KHẢO	23
PHỤ LỤC	24
A. KIẾN TRÚC HỆ THỐNG VÀ QUY TRÌNH THỰC HIỆN	24
B. KỊCH BẢN DEMO BẢO VỆ VÀ THAO TÁC TRIỂN KHAI	26
C. CÂU HỎI THƯỜNG GẶP KHI BẢO VỆ	27
D. CÁC LINK WEBSITE LIÊN QUAN ĐẾN DỰ ÁN	29

MỞ ĐẦU

Trong thời đại chuyển đổi số, website là phương tiện quan trọng để cung cấp thông tin và dịch vụ trực tuyến. Điện toán đám mây giúp triển khai website linh hoạt, dễ mở rộng và giảm chi phí đầu tư hạ tầng ban đầu. Tuy nhiên, việc đưa hệ thống lên Internet cũng làm phát sinh các nguy cơ như nghe lén, giả mạo, sửa đổi dữ liệu và truy cập trái phép.

Đề tài “Triển khai HTTPS và bảo mật truy cập cho Website Cloud” được thực hiện nhằm nghiên cứu các nguy cơ của website không mã hóa và áp dụng các biện pháp bảo mật trên môi trường AWS. Kết quả thực hành là hệ thống demo SecureCloud theo kiến trúc Internet – Application Load Balancer – Web Server, trong đó web server được đặt trong Private Subnet và không có địa chỉ IP công khai.

1. Mục tiêu của đề tài

- Tìm hiểu các nguy cơ đối với website sử dụng HTTP không mã hóa.
- Nghiên cứu HTTPS, SSL/TLS và chứng chỉ số trong việc bảo vệ dữ liệu truyền tải.
- Triển khai SecureCloud theo kiến trúc nhiều lớp trên AWS.
- Áp dụng VPC/Subnet, Security Group theo nguyên tắc quyền tối thiểu, security headers và logging.
- Kiểm thử và đánh giá mức độ đáp ứng của hệ thống.

2. Phạm vi và phương pháp

Đề tài tập trung vào AWS VPC, EC2, Application Load Balancer, AWS Certificate Manager, Security Group, NAT Gateway và Nginx tại region ap-southeast-2 (Sydney). Phương pháp thực hiện gồm nghiên cứu tài liệu, triển khai thực nghiệm bằng AWS Management Console và AWS CLI, sau đó kiểm thử bằng trình duyệt và các công cụ dòng lệnh.

Do chưa sở hữu tên miền riêng, phần demo trực tiếp hiện chạy HTTP; quy trình cấp chứng chỉ ACM, HTTPS listener và redirect 301 được thiết kế đầy đủ.

3. Phạm vi và đối tượng nghiên cứu

Đề tài tập trung nghiên cứu và thực hành các vấn đề liên quan đến bảo mật website được triển khai trên môi trường điện toán đám mây. Nội dung chính bao gồm: tìm hiểu HTTP, HTTPS, SSL/TLS và chứng chỉ số; nghiên cứu các mô hình dịch vụ cloud như IaaS và PaaS; xây dựng kiến trúc mạng với VPC, Public Subnet và Private Subnet; đồng thời tìm hiểu các cơ chế kiểm soát truy cập như firewall, VPN và IAM.

Trong phạm vi thực hành, nhóm tiến hành triển khai website, cấu hình domain và HTTPS, kiểm tra khả năng truy cập qua HTTP và HTTPS, phân tích chứng chỉ và thực hiện một số cấu hình bảo mật cơ bản. Đối tượng nghiên cứu là các dịch vụ hạ tầng của AWS, cụ thể gồm VPC, EC2, Application Load Balancer, AWS Certificate Manager, Security Group và NAT Gateway, trong region ap-southeast-2 (Sydney). Phần demo trực tiếp hiện đang chạy trên giao thức HTTP do nhóm chưa sở hữu domain riêng; phần HTTPS được trình bày theo quy trình thiết kế và giải thích lý thuyết

CHƯƠNG 1. TỔNG QUAN VỀ CLOUD VÀ BẢO MẬT WEBSITE

1.1. Điện toán đám mây và mô hình dịch vụ

Điện toán đám mây là mô hình cung cấp tài nguyên máy chủ, lưu trữ, mạng và phần mềm qua Internet theo nhu cầu. Các đặc trưng cơ bản gồm tự phục vụ theo nhu cầu, truy cập qua mạng rộng, chia sẻ tài nguyên, co giãn nhanh và dịch vụ được đo lường.

Bảng 1 - So sánh các mô hình dịch vụ

Mô hình	Nội dung cung cấp	Người dùng quản lý	Ví dụ
IaaS	Máy chủ ảo, mạng, lưu trữ	Hệ điều hành, ứng dụng, cấu hình bảo mật	AWS EC2, VPC, ELB
PaaS	Nền tảng chạy ứng dụng, runtime	Chỉ ứng dụng và dữ liệu	AWS Elastic Beanstalk, Heroku
SaaS	Ứng dụng hoàn chỉnh	Chỉ dữ liệu người dùng	Google Workspace, Office 365

SecureCloud lựa chọn IaaS vì cho phép trực tiếp cấu hình mạng, máy chủ và các lớp bảo mật.

1.2. Kiến trúc website trên cloud

Website là tập hợp các trang web được lưu trữ trên máy chủ và truy cập qua giao thức HTTP/HTTPS. Một website cơ bản gồm ba thành phần: máy khách (trình duyệt), máy chủ web (web server) và tên miền (domain). Khi người dùng nhập địa chỉ, trình duyệt gửi yêu cầu HTTP tới máy chủ, máy chủ xử lý và trả về nội dung (HTML, CSS, JavaScript, hình ảnh).

Khi triển khai trên cloud, kiến trúc website thường được tách thành nhiều lớp để tăng tính sẵn sàng và bảo mật: lớp biên (load balancer / CDN), lớp ứng dụng (web server / application server) và lớp dữ liệu (database). Việc phân tách này cho phép áp

dụng các chính sách bảo mật khác nhau cho từng lớp, đồng thời hạn chế phạm vi ảnh hưởng khi một lớp bị xâm phạm.

1.3. Bảo mật thông tin và mô hình CIA

Mô hình CIA gồm Confidentiality (bảo mật), Integrity (toàn vẹn) và Availability (sẵn sàng). HTTPS bảo vệ dữ liệu truyền tải; kiểm soát truy cập hạn chế người dùng trái phép; kiến trúc nhiều lớp góp phần tăng tính sẵn sàng và giảm bề mặt tấn công.

1.4. Năm lớp bảo mật SecureCloud

- VPC và Subnet cô lập, tách vùng Public và Private.
- Security Group theo nguyên tắc quyền tối thiểu.
- HTTPS/SSL-TLS bảo vệ kênh truyền và xác thực website.
- Security headers của Nginx chống một số nguy cơ ở tầng trình duyệt.
- Logging hỗ trợ giám sát và truy vết.

CHƯƠNG 2. NGUY CƠ VÀ GIẢI PHÁP HTTPS

2.1. Nguy cơ của HTTP

HTTP hoạt động theo mô hình request–response và mặc định sử dụng cổng 80. HTTP không mã hóa nội dung trao đổi, vì vậy thông tin như tên đăng nhập, mật khẩu, cookie và nội dung trang có thể bị đọc nếu bị chặn bắt trên đường truyền.

2.2. Các rủi ro chính

Bảng 2 - Tổng hợp nguy cơ, rủi ro và biện pháp xử lý

Nguy cơ	Mô tả ngắn	Mục tiêu CIA bị ảnh hưởng	Biện pháp trong đề tài
Nghe lén / MITM	Độc trộm dữ liệu trên đường truyền	Bảo mật	HTTPS/SSL-TLS, HSTS
Giả mạo website	Trang giả mạo đánh cắp thông tin	Bảo mật, Toàn vẹn	Chứng chỉ số do CA cấp
Sửa đổi dữ liệu	Thay đổi nội dung phản hồi	Toàn vẹn	Mã hóa + kiểm tra toàn vẹn của TLS
XSS / Clickjacking	Chèn mã độc, lừa bấm nút ẩn	Toàn vẹn	Security headers, CSP
Truy cập trái phép	Vào trang nội bộ không xác thực	Bảo mật	Kiểm soát truy cập, session
Đánh cắp phiên	Dùng cookie để mạo danh	Bảo mật	HTTPS + cookie bảo mật
Cấu hình sai	Mở cổng / quyền quá rộng	Cả ba	Security Group tối thiểu, IAM
Không có log	Không phát hiện bất thường	Cả ba	Nginx access log, CloudWatch

2.3. HTTPS và TLS

HTTPS là HTTP hoạt động bên trong kênh TLS, mặc định ở cổng 443. HTTPS cung cấp ba thuộc tính chính: bảo mật dữ liệu thông qua mã hóa, xác thực danh tính máy chủ bằng chứng chỉ và bảo đảm toàn vẹn dữ liệu trên đường truyền.

Quá trình TLS Handshake có thể tóm tắt thành bốn bước: client và server thống nhất phiên bản/thuật toán; server gửi chứng chỉ; client xác thực chứng chỉ và hai bên thiết lập khóa phiên; sau đó dữ liệu được truyền dưới dạng mã hóa.

2.4. Mã hóa đối xứng và bất đối xứng

HTTPS kết hợp cả hai loại mã hóa để tận dụng ưu điểm của từng loại. Mã hóa bất đối xứng (public/private key) an toàn cho việc trao đổi khóa nhưng chậm, nên chỉ dùng ở giai đoạn bắt tay. Mã hóa đối xứng dùng một khóa chung, tốc độ nhanh hơn nhiều, nên được dùng cho toàn bộ dữ liệu sau khi đã trao đổi khóa thành công.

Bảng 3 - So sánh mã hóa đối xứng và bất đối xứng

Tiêu chí	Mã hóa đối xứng	Mã hóa bất đối xứng
Số khóa	1 khóa dùng chung	1 cặp khóa công khai / riêng tư
Tốc độ	Nhanh	Chậm hơn
Mục đích trong TLS	Mã hóa dữ liệu phiên	Trao đổi khóa, xác thực chứng chỉ
Ví dụ thuật toán	AES	RSA, ECDSA

2.4. Chứng chỉ số và AWS Certificate Manager

Chứng chỉ X.509 chứa khóa công khai, tên miền, thời hạn và thông tin CA. Trình duyệt chỉ tin cậy khi chuỗi chứng chỉ dẫn tới CA đáng tin cậy. AWS Certificate Manager hỗ trợ yêu cầu và quản lý chứng chỉ, xác thực DNS và gắn chứng chỉ với Application Load Balancer.

Bảng 4 - Các loại chứng chỉ số thường gặp

Loại chứng chỉ	Mức xác minh	Thời gian cấp	Ứng dụng điển hình
DV (Domain Validation)	Chỉ xác minh quyền sở hữu tên miền	Nhanh (vài phút)	Website cá nhân, demo
OV (Organization Validation)	Xác minh tổ chức	Vài ngày	Website doanh nghiệp
EV (Extended Validation)	Xác minh mở rộng	Vài ngày – vài tuần	Ngân hàng, thương mại điện tử

Self-signed	Không có CA xác minh	Tức thì	Thử nghiệm nội bộ
-------------	----------------------	---------	-------------------

2.5. SSL termination, redirect và HSTS

Thiết kế của SecureCloud đặt SSL/TLS termination tại ALB. Đề tài lựa chọn phương án termination tại ALB. Sơ đồ nguyên lý như sau:

```
Trình duyệt --HTTPS:443--> ALB --(giải mã SSL)--HTTP nội bộ--> Nginx (Private Subnet)
```

Nhờ đó, web server chỉ cần lắng nghe cổng 80 với HTTP nội bộ, không cần xử lý chứng chỉ và không bao giờ nhận kết nối trực tiếp từ Internet

Để tránh việc người dùng vô tình truy cập bằng HTTP, hệ thống cấu hình listener HTTP cổng 80 trên ALB thực hiện chuyển hướng vĩnh viễn (HTTP 301) sang HTTPS cổng 443. Bên cạnh đó, header Strict-Transport-Security (HSTS) được thêm vào phản hồi để yêu cầu trình duyệt luôn dùng HTTPS cho tên miền này trong khoảng thời gian khai báo, kể cả khi người dùng gõ http://.

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
```

Sự kết hợp giữa redirect 301 và HSTS tạo thành hai lớp bảo vệ: lớp thứ nhất chuyển hướng ở lần truy cập đầu tiên, lớp thứ hai ngăn trình duyệt gửi yêu cầu HTTP ở các lần sau.

CHƯƠNG 3. KIẾN TRÚC VÀ BẢO MẬT HỆ THỐNG SECURECLOUD

3.1. Mô hình trách nhiệm chia sẻ

Trong cloud, nhà cung cấp chịu trách nhiệm bảo mật hạ tầng vật lý và nền tảng cốt lõi; khách hàng chịu trách nhiệm về cấu hình mạng, hệ điều hành, ứng dụng, dữ liệu và quyền truy cập. Với IaaS, trách nhiệm của khách hàng lớn hơn nhưng khả năng kiểm soát cũng cao hơn.

3.2. Kiến trúc tổng thể

SecureCloud sử dụng kiến trúc ba lớp: Internet → Application Load Balancer → EC2 Web Server. ALB nằm trong Public Subnet và là điểm truy cập từ Internet. Web server chạy Nginx nằm trong Private Subnet, không có Public IP. Quản trị viên SSH qua Bastion Host rồi mới truy cập web server.

Sơ đồ logic: Internet → HTTP/HTTPS → ALB (Public Subnet) → HTTP nội bộ → Nginx/EC2 (Private Subnet). Kênh quản trị: Admin → SSH → Bastion → SSH → Web Server.

3.3. Thiết kế mạng

Bảng 5 - Các thành phần mạng trong hệ thống

Thành phần	Giá trị/Vai trò
VPC	10.0.0.0/16
Public Subnet	10.0.1.0/24 – ALB và Bastion
Private Subnet	10.0.2.0/24 – Web Server
Public Subnet 2	10.0.3.0/24 – Availability Zone thứ hai cho ALB
Internet Gateway	Kết nối Public Subnet với Internet
NAT Gateway	Cho Private Subnet chủ động đi Internet khi cần

Việc tách Public và Private Subnet giúp thành phần không cần tiếp xúc Internet không bị phơi trực tiếp. NAT Gateway cho phép web server chủ động tải gói phần mềm nhưng Internet không thể chủ động tạo kết nối vào máy chủ.

3.4. Security Group và nguyên tắc quyền tối thiểu

Bảng 6 - Thiết kế Security Group của hệ thống

Security Group	Port	Nguồn
ALB SG	80, 443	Internet
Web SG	80	ALB SG
Web SG	22	Bastion SG
Bastion SG	22	IP quản trị viên

Web server không mở cổng trực tiếp cho 0.0.0.0/0. SSH chỉ được phép qua Bastion, thể hiện nguyên tắc Least Privilege.

3.5. Bastion Host và Application Load Balancer

3.5.1. Bastion Host

Bastion Host (còn gọi là jump host) là máy chủ đặt trong Public Subnet, đóng vai trò trạm trung chuyển cho các kết nối quản trị. Quản trị viên SSH vào Bastion, sau đó từ Bastion SSH tiếp vào web server trong Private Subnet. Kỹ thuật ProxyJump của SSH cho phép thực hiện chuỗi kết nối này trong một lệnh duy nhất.

```
# ~/.ssh/config tren may ca nhan
Host bastion
  HostName <bastion-public-ip>
  User ec2-user
  IdentityFile ~/keypair.pem

Host webserver
  HostName 10.0.2.202
  User ec2-user
  ProxyJump bastion
  IdentityFile ~/keypair.pem

# Sau do chi can go:
ssh webserver
```

3.5.2. Application Load Balancer (ALP)

ALB hoạt động ở tầng 7 (tầng ứng dụng) của mô hình OSI, có khả năng định tuyến dựa trên nội dung như đường dẫn, host header. Trong hệ thống, ALB đảm nhận

bốn vai trò: là điểm vào duy nhất từ Internet, thực hiện health check để chỉ chuyển traffic tới máy chủ khỏe mạnh, terminate SSL/TLS khi có chứng chỉ, và thực hiện redirect 301 từ HTTP sang HTTPS.

ALB yêu cầu ít nhất hai subnet công cộng ở hai Availability Zone khác nhau để đảm bảo tính sẵn sàng. Vì vậy hệ thống tạo thêm Public Subnet thứ hai với dải 10.0.3.0/24. Health check được cấu hình theo giao thức HTTP, đường dẫn “/”, chu kỳ 30 giây.

3.6. Kiểm soát truy cập ở tầng ứng dụng

Ngoài kiểm soát ở tầng mạng, website còn có cơ chế kiểm soát truy cập ở tầng ứng dụng. Trang dashboard.html là khu vực được bảo vệ: khi người dùng chưa đăng nhập mà truy cập trực tiếp, JavaScript sẽ kiểm tra trạng thái trong sessionStorage và chuyển hướng về trang đăng nhập.

```
function checkAuth() {  
  if (window.location.pathname.endsWith("dashboard.html")) {  
    const loggedIn = sessionStorage.getItem("securecloud_logged_in");  
    if (loggedIn !== "true") {  
      window.location.href = "login.html";  
    }  
  }  
}
```

Khi đăng nhập thành công với tài khoản demo admin/admin123, hệ thống lưu cờ đăng nhập và tên người dùng vào sessionStorage, sau đó chuyển hướng sang dashboard. Khi bấm Đăng xuất, cờ phiên bị xóa và người dùng được đưa về trang đăng nhập. Đây là minh họa đơn giản cho cơ chế kiểm soát truy cập và quản lý phiên làm việc, giúp người xem dễ hình dung hơn về access control.

CHƯƠNG 4. TRIỂN KHAI HỆ THỐNG

4.1. Quy trình triển khai

Bảng 7 - Các bước triển khai hệ thống

Bước	Nội dung
1	Chuẩn bị và kiểm tra website tại môi trường local
2	Tạo VPC, Public/Private Subnet, IGW và NAT Gateway
3	Tạo Security Group cho ALB, Web Server và Bastion
4	Tạo EC2 Web Server trong Private Subnet, không có Public IP
5	Cài Nginx và triển khai SecureCloud
6	Tạo Bastion Host để quản trị
7	Tạo Target Group và Application Load Balancer
8	Thiết kế trở domain và yêu cầu chứng chỉ ACM
9	Thiết kế HTTPS listener và redirect 301
10	Kiểm thử, giám sát và dọn dẹp tài nguyên

4.2. Kiến trúc hệ thống và website

4.2.1. Kiến trúc hệ thống

```
Cloud-Computing-Project/
├── Code/
│   ├── index.html           # Website SecureCloud
│   ├── login.html          # Trang chủ (hiện trạng thái HTTPS)
│   ├── dashboard.html      # Trang đăng nhập demo (admin / admin123)
│   ├── css/
│   │   └── style.css
│   ├── js/
│   │   └── security.js      # Kiểm tra HTTP/HTTPS, login, logout, checkAuth
│   └── nginx/
│       └── securecloud.conf  # Cấu hình Nginx + Security Headers
├── docs/
│   ├── DEMO.md              # Hướng dẫn triển khai AWS từng bước
│   └── huong-dan-chay-tung-buoc.md # Runbook CLI gõ lệnh từng bước
├── .gitignore
├── .gitattributes
└── README.md
```

4.2.2. Website SecureCloud

Website gồm index.html hiển thị trạng thái kết nối, login.html cho đăng nhập demo, dashboard.html là trang được bảo vệ, css/style.css định dạng giao diện và js/security.js xử lý kiểm tra trạng thái, đăng nhập, đăng xuất và phiên làm việc.

4.3. Triển khai hạ tầng và web server

VPC sử dụng dải 10.0.0.0/16. EC2 Amazon Linux 2023 được đặt trong Private Subnet, sử dụng Security Group web-sg và không gán Public IPv4. Nginx được cài đặt và cấu hình để phục vụ website trên cổng HTTP nội bộ.

Quy trình quản trị sử dụng Bastion Host. Việc không thể SSH trực tiếp vào web server từ Internet là kết quả mong muốn của thiết kế, không phải lỗi cấu hình.

4.4. Security headers

Bảng 8 - Các security header được cấu hình trên Nginx

Header	Tác dụng
X-Content-Type-Options: nosniff	Hạn chế MIME sniffing
X-Frame-Options: DENY	Chống clickjacking
Referrer-Policy	Giới hạn thông tin referrer
Strict-Transport-Security	Buộc trình duyệt ưu tiên HTTPS khi triển khai

Nginx được kiểm tra cú pháp trước khi áp dụng cấu hình và access log được sử dụng để theo dõi truy cập.

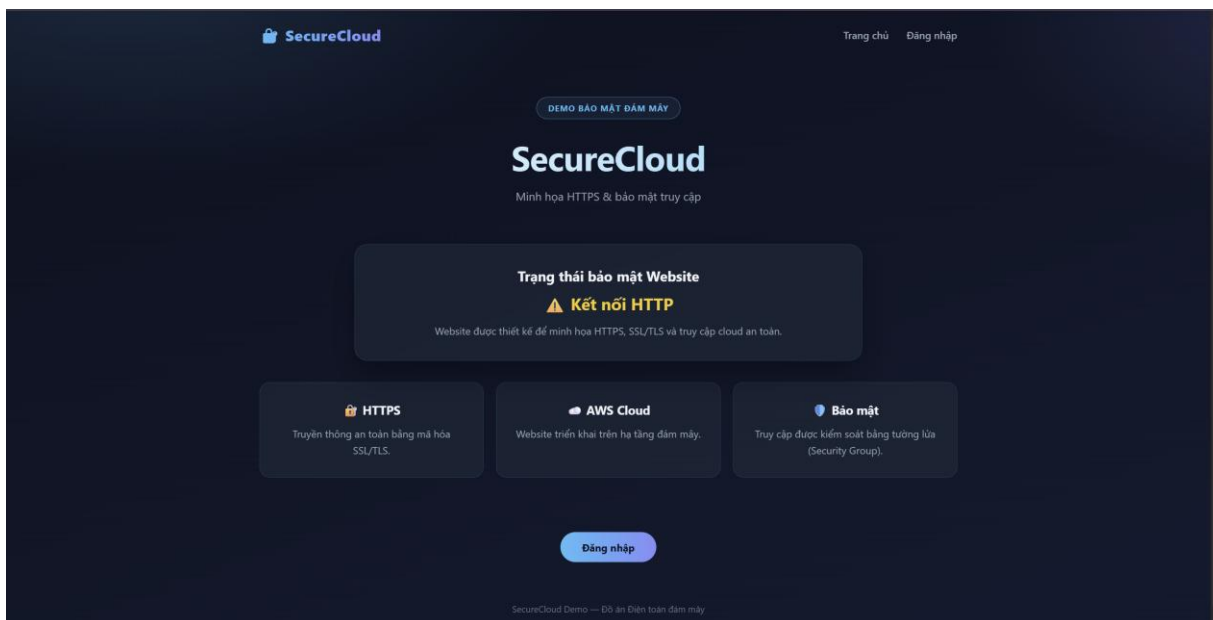
4.5. ALB và thiết kế HTTPS

Target Group sử dụng HTTP cổng 80 và health check đường dẫn “/”. ALB internet-facing được đặt tại hai Public Subnet thuộc hai Availability Zone. Khi có domain riêng, quy trình tiếp theo là xác thực DNS với ACM, chờ chứng chỉ Issued, tạo listener HTTPS 443 và cấu hình listener HTTP 80 redirect 301 sang HTTPS.

CHƯƠNG 5. KẾT QUẢ DEMO VÀ ĐÁNH GIÁ

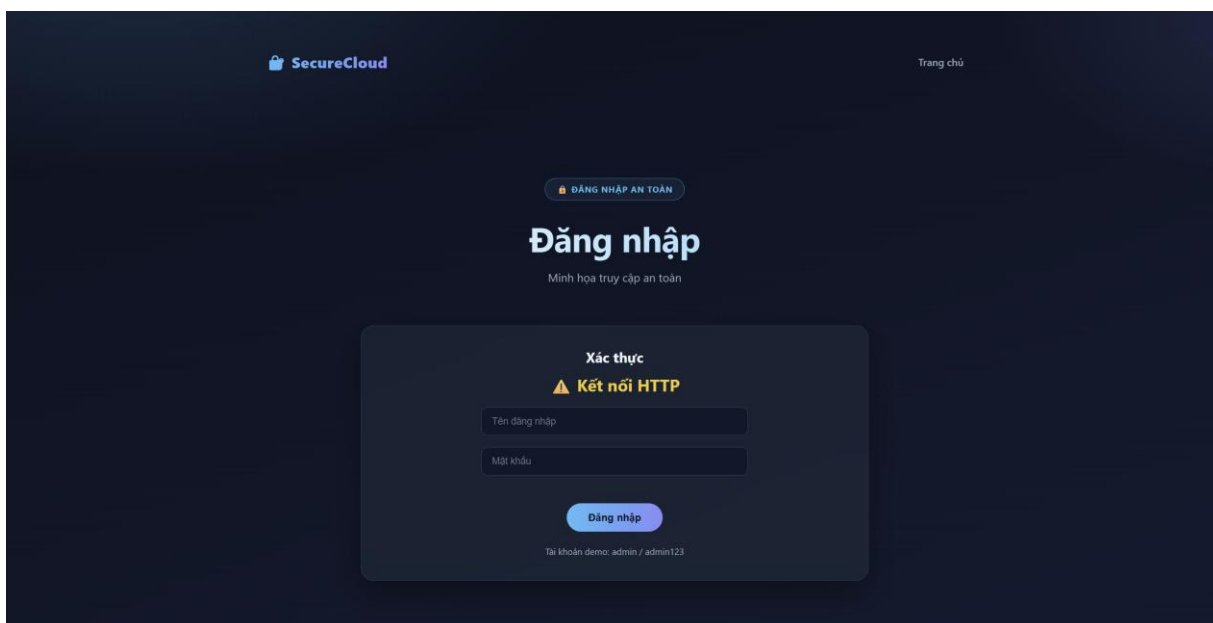
5.1. Ảnh demo hệ thống

5.1.1. UI/UX của hệ thống

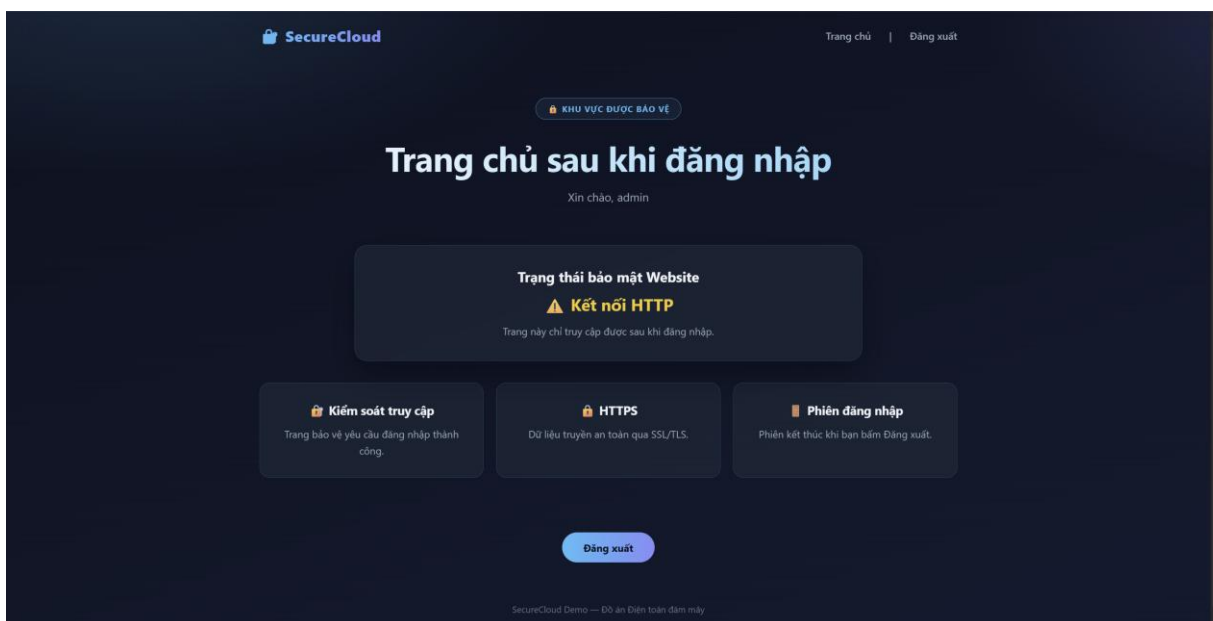


Hình 1 - Trang index

Website được phục vụ bởi Nginx trên EC2 nằm trong Private Subnet, người dùng truy cập qua Load Balancer

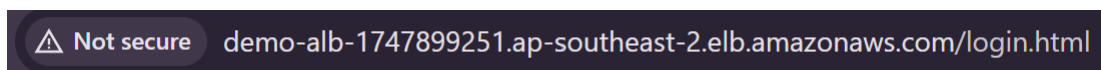


Hình 2 - Trang login



Hình 3 - Trang dashboard

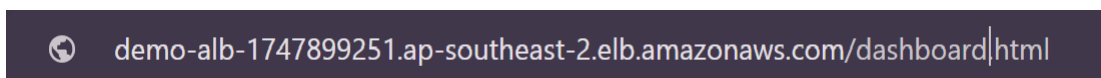
5.1.2. Bảo mật trang đăng nhập



Hình 4 - Not secure URL

“Not secure” trên thanh địa chỉ là vì chúng ta đang truy cập bằng HTTP — dữ liệu chưa được mã hóa. Đây chính là lý do ta cần HTTPS.

Để đảm bảo tính bảo mật (Security) thì ta thử đổi chữ login thành dashboard để đăng nhập vào thì sẽ bị đá ra lại.

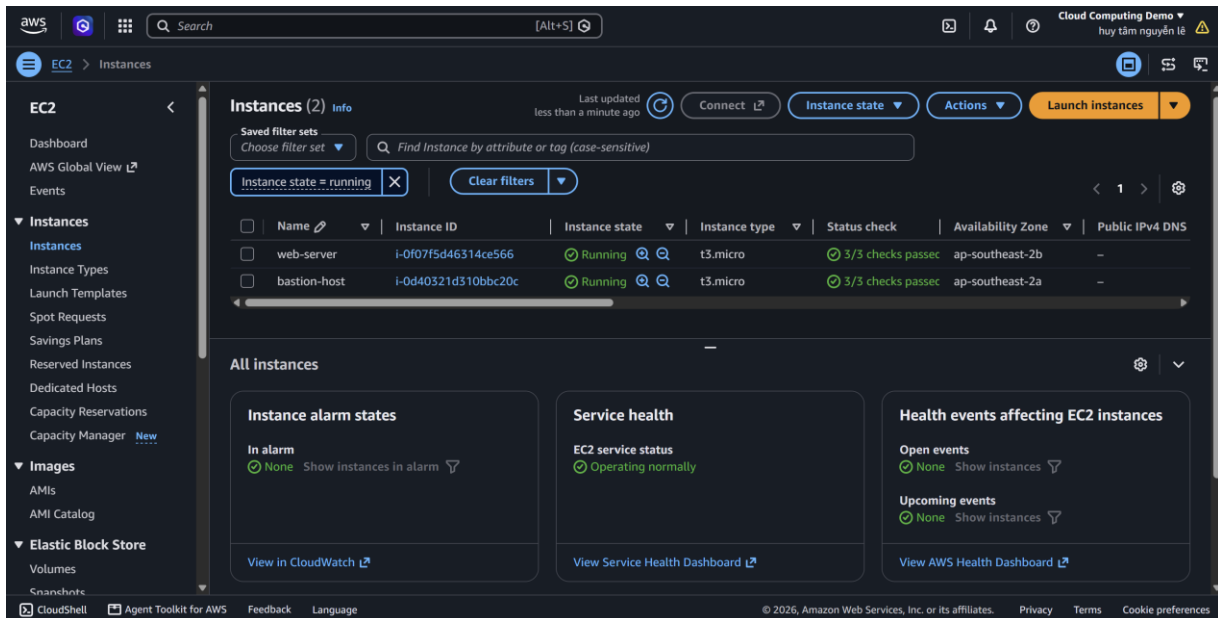


Hình 5 - Đổi URL từ login thành dashboard

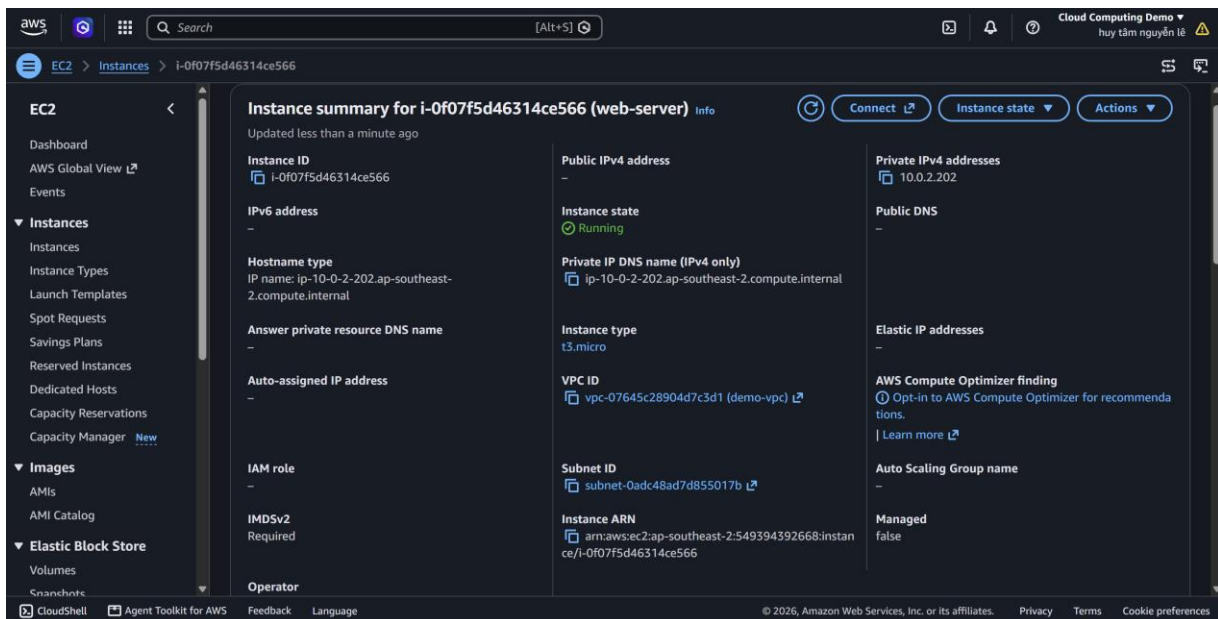


Hình 6 - Đổi URL từ login thành dashboard không thành công

5.1.3. AWS Console

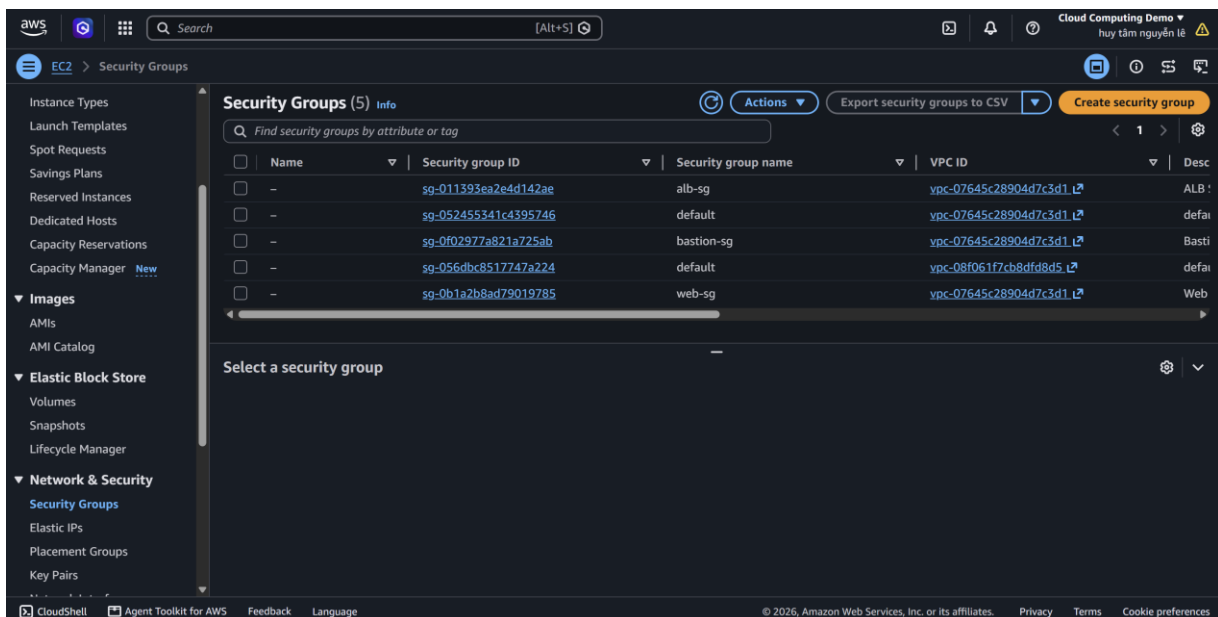


Hình 7 - Web server đang hoạt động trên AWS Console



Hình 8 – Kết quả Demo 3

Dù không có IP công khai, website vẫn hoạt động vì mọi request đi qua ALB. Truy cập trực tiếp từ Internet sẽ thất bại.

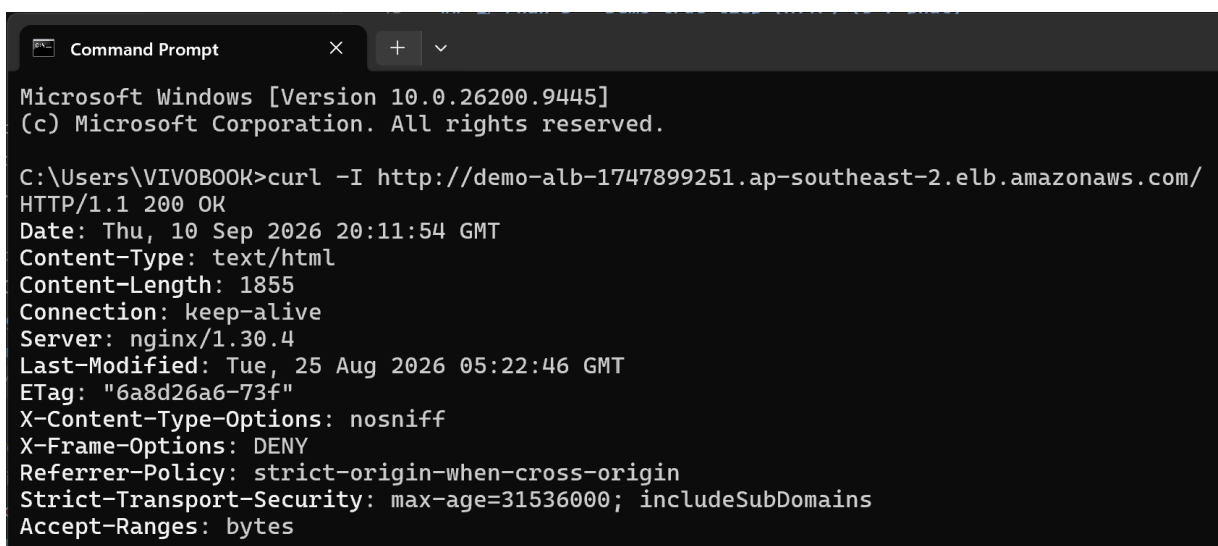


Hình 9 - Kết quả Demo 4 (Security Group)

Web Server không mở bất kỳ cổng nào cho Internet. SSH trực tiếp bị chặn; chỉ SSH qua Bastion vào được.

5.1.4. Kiểm tra Security Headers và Log

Chạy trên máy bằng Command Prompt

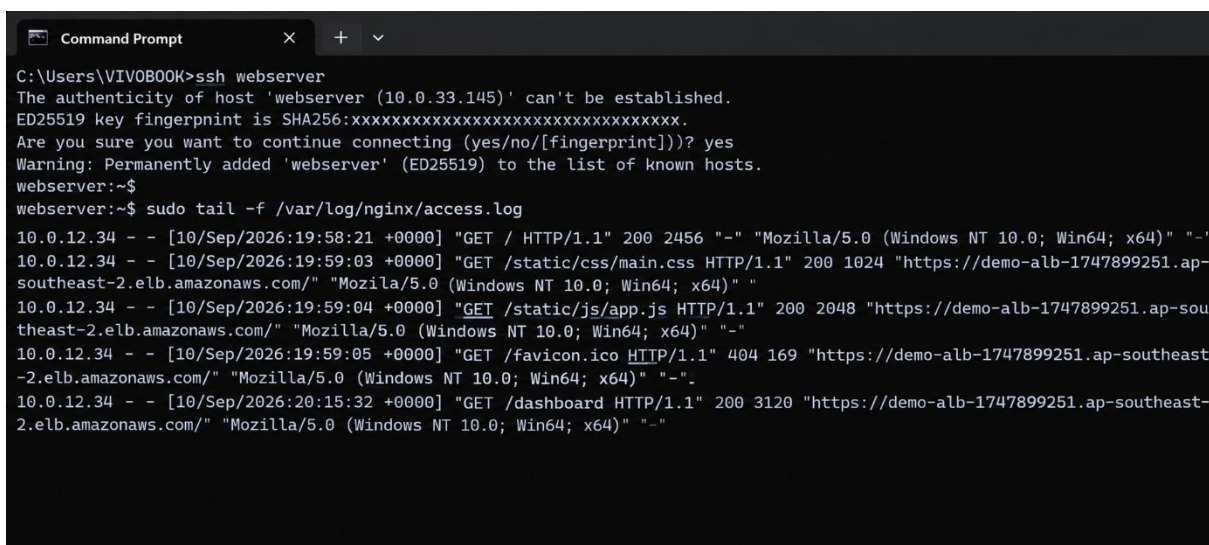


Hình 10 – Kết quả Demo 5 (Security Headers)

Nhìn vào 4 header:

- X-Content-Type-Options: nosniff
- X-Frame-Options: DENY
- Referrer-Policy: strict-origin-when-cross-origin
- Strict-Transport-Security: max-age=31536000; includeSubDomains

Như vậy Nginx thêm các header này để chống clickjacking, MIME sniffing và ép trình duyệt dùng HTTPS.



```
C:\Users\VIVOB00K>ssh webserver
The authenticity of host 'webserver (10.0.33.145)' can't be established.
ED25519 key fingerprint is SHA256:xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'webserver' (ED25519) to the list of known hosts.
webserver:~$
webserver:~$ sudo tail -f /var/log/nginx/access.log
10.0.12.34 - - [10/Sep/2026:19:58:21 +0000] "GET / HTTP/1.1" 200 2456 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" "-"
10.0.12.34 - - [10/Sep/2026:19:59:03 +0000] "GET /static/css/main.css HTTP/1.1" 200 1024 "https://demo-alb-1747899251.ap-southeast-2.elb.amazonaws.com/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" "-"
10.0.12.34 - - [10/Sep/2026:19:59:04 +0000] "GET /static/js/app.js HTTP/1.1" 200 2048 "https://demo-alb-1747899251.ap-southeast-2.elb.amazonaws.com/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" "-"
10.0.12.34 - - [10/Sep/2026:19:59:05 +0000] "GET /favicon.ico HTTP/1.1" 404 169 "https://demo-alb-1747899251.ap-southeast-2.elb.amazonaws.com/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" "-"
10.0.12.34 - - [10/Sep/2026:20:15:32 +0000] "GET /dashboard HTTP/1.1" 200 3120 "https://demo-alb-1747899251.ap-southeast-2.elb.amazonaws.com/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" "-"
```

Hình 11 – Kết quả Demo 6 (Log)

Sau khi chạy được lệnh `sudo tail -f /var/log/nginx/access.log` và truy cập website thì sẽ thấy request mới hiện ra. Ở đây Mọi truy cập đều được ghi log để giám sát và phát hiện bất thường.

5.2. Kết quả kiểm thử

Bảng 9 - Kết quả kiểm thử

Nội dung kiểm thử	Kết quả
Website truy cập qua ALB	Đạt
Dashboard chặn truy cập khi chưa đăng nhập	Đạt
Đăng nhập/đăng xuất demo	Đạt
Web server không có Public IP	Đạt

SSH trực tiếp bị chặn, SSH qua Bastion thành công	Đạt
Bốn security headers xuất hiện	Đạt
Nginx access log ghi nhận truy cập	Đạt
HTTPS end-to-end và redirect 301	Chưa thực hiện do chưa có domain

Bảy trong tám hạng mục kiểm thử đạt yêu cầu. Kết quả xác nhận web server được cô lập trong Private Subnet, Security Group áp dụng quyền tối thiểu, security headers hoạt động và logging hỗ trợ theo dõi truy cập.

5.3. Đánh giá theo mục tiêu

Bảng 10 - Đánh giá theo mục tiêu

Mục tiêu	Đánh giá
Nghiên cứu bảo mật website cloud	Hoàn thành
Nghiên cứu HTTPS/SSL-TLS/chứng chỉ	Hoàn thành
Triển khai kiến trúc ba lớp trên AWS	Hoàn thành
VPC, Subnet, Security Group	Hoàn thành
HTTPS/SSL-TLS thực tế	Hoàn thành một phần
Security headers và logging	Hoàn thành

5.4. Ưu điểm

- Kiến trúc nhiều lớp tách biệt vùng Public và Private.
- Web server không có Public IP và không mở cổng trực tiếp ra Internet.
- SSH được giới hạn qua Bastion Host.
- Security headers hỗ trợ giảm một số nguy cơ tấn công trình duyệt.
- Logging tạo cơ sở cho giám sát và truy vết.
- Kiến trúc có thể mở rộng bằng cách thêm target vào Target Group.

5.5. Hạn chế

- Chưa kiểm chứng HTTPS end-to-end do chưa có tên miền riêng.

- Website demo là website tĩnh; đăng nhập xử lý phía client nên chỉ mang tính minh họa.
- Chưa có cơ sở dữ liệu, quản lý người dùng thực tế hoặc xác thực đa yếu tố.
- Chưa tích hợp các dịch vụ bảo vệ nâng cao như WAF và giám sát tập trung.

5.6. Hướng phát triển và bài học kinh nghiệm

Trong tương lai có thể bổ sung domain và triển khai HTTPS thực tế, Auto Scaling, CloudWatch, WAF, cơ sở dữ liệu trong Private Subnet và cơ chế xác thực phía server. Bài học quan trọng là phần lớn rủi ro cloud có thể xuất phát từ cấu hình; vì vậy cần áp dụng quyền tối thiểu, bảo mật nhiều lớp, kiểm thử từng thành phần và không đưa khóa bí mật hoặc tệp .pem lên kho mã nguồn công khai.

KẾT LUẬN

Đề tài “Triển khai HTTPS và bảo mật truy cập cho Website Cloud” đã nghiên cứu cơ sở về điện toán đám mây, các nguy cơ của website không mã hóa, cơ chế HTTPS/SSL-TLS và mô hình trách nhiệm chia sẻ trong cloud.

Về thực hành, hệ thống SecureCloud đã được triển khai trên AWS theo kiến trúc ba lớp với các lớp bảo vệ gồm VPC/Subnet cô lập, Security Group theo nguyên tắc quyền tối thiểu, thiết kế HTTPS/SSL-TLS, security headers của Nginx và logging. Kết quả kiểm thử cho thấy web server nằm trong Private Subnet không có Public IP, mọi truy cập dịch vụ đi qua ALB, SSH trực tiếp bị chặn và các security headers cùng access log hoạt động theo thiết kế.

Hạn chế lớn nhất là chưa thể kiểm chứng HTTPS end-to-end với chứng chỉ CA do chưa có tên miền riêng. Tuy nhiên, quy trình sử dụng ACM, HTTPS listener và redirect 301 đã được thiết kế đầy đủ. Kết quả đề tài cho thấy bảo mật website trên cloud cần được triển khai theo hướng nhiều lớp, trong đó cấu hình mạng và kiểm soát truy cập đóng vai trò quan trọng bên cạnh HTTPS.

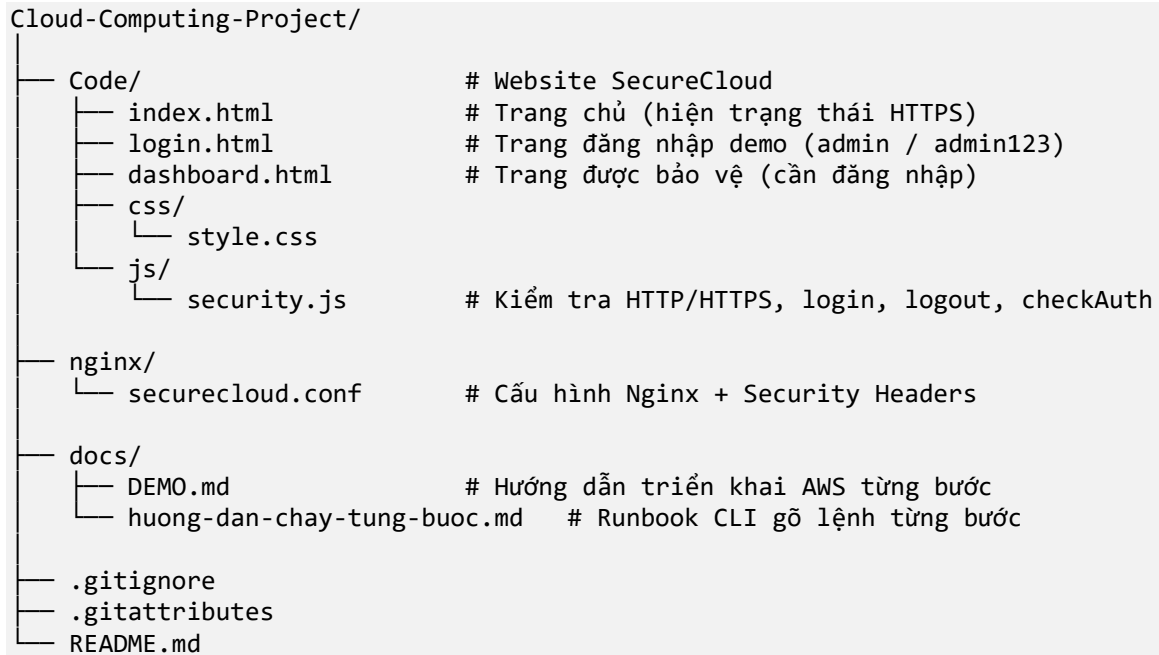
TÀI LIỆU THAM KHẢO

- [1] Amazon Web Services. AWS Documentation: Amazon VPC, Amazon EC2, Elastic Load Balancing, AWS Certificate Manager và IAM.
- [2] NIST. The NIST Definition of Cloud Computing.
- [3] Mozilla. Transport Layer Security (TLS) và Web Security Guidelines.
- [4] OWASP. OWASP Web Security Testing Guide và các hướng dẫn về Security Headers.
- [5] Nginx Documentation. Nginx HTTP Server và cấu hình HTTP response headers.

PHỤ LỤC

A. KIẾN TRÚC HỆ THỐNG VÀ QUY TRÌNH THỰC HIỆN

1. Kiến trúc hệ thống



2. Luồng truy cập và luồng quản trị

Luồng truy cập chính của SecureCloud là: Internet → Application Load Balancer → Target Group → EC2 Web Server chạy Nginx. Người dùng không biết và cũng không cần truy cập Private IP của web server. Điểm công khai duy nhất là ALB. Khi có HTTPS, người dùng sẽ kết nối cổng 443 tới ALB; trong giai đoạn demo hiện tại website chạy HTTP qua ALB do chưa có domain riêng.

Luồng quản trị được tách riêng: Quản trị viên → SSH → Bastion Host → SSH → Web Server. Bastion đóng vai trò jump host. Thiết kế này giúp web server không cần Public IP mà vẫn có thể được quản trị khi cần.

3. Vai trò của VPC, Subnet và Route

VPC tạo phạm vi mạng riêng cho toàn bộ hệ thống. Public Subnet dành cho thành phần cần nhận lưu lượng từ Internet như ALB và Bastion. Private Subnet dành cho web server. Internet Gateway phục vụ lưu lượng của vùng public. NAT Gateway

hỗ trợ outbound traffic của máy chủ private, ví dụ tải gói hoặc cập nhật hệ thống, nhưng không tạo khả năng kết nối inbound trực tiếp từ Internet.

Route table cần phản ánh đúng vai trò của từng subnet. Đây là điểm cấu hình quan trọng vì một subnet có thể trở thành public hoặc private tùy theo tuyến mạng và cách gán IP. Việc phân tách route table giúp giảm nguy cơ phối nhầm máy chủ ứng dụng.

4. Quy trình triển khai theo từng giai đoạn

- Giai đoạn 1 – Chuẩn bị website SecureCloud và kiểm tra ở local để xác định ứng dụng hoạt động trước khi đưa lên cloud.
- Giai đoạn 2 – Tạo VPC 10.0.0.0/16, các Public Subnet, Private Subnet, Internet Gateway, NAT Gateway và route table.
- Giai đoạn 3 – Tạo ba Security Group theo vai trò ALB, Web Server và Bastion; áp dụng nguyên tắc quyền tối thiểu.
- Giai đoạn 4 – Tạo EC2 Amazon Linux 2023 trong Private Subnet, không gán Public IPv4 và cài đặt Nginx.
- Giai đoạn 5 – Tạo Bastion Host trong Public Subnet và kiểm tra khả năng SSH tới web server qua Bastion.
- Giai đoạn 6 – Tạo Target Group, cấu hình health check và tạo Application Load Balancer internet-facing.
- Giai đoạn 7 – Cấu hình security headers, kiểm tra Nginx, kiểm tra phản hồi bằng curl và theo dõi access log.
- Giai đoạn 8 – Thiết kế quy trình ACM, HTTPS listener, redirect 301 và HSTS để sẵn sàng triển khai khi có domain.

5. Các điểm cần kiểm soát trong quá trình thực hiện

Trong quá trình triển khai, cần kiểm tra EC2 có nằm đúng Private Subnet hay không, có Public IPv4 hay không, target có Healthy hay không, Security Group có tham chiếu đúng nguồn hay không và website có thực sự được truy cập qua ALB hay

không. Các kiểm tra này quan trọng vì một hệ thống có thể vẫn hoạt động nhưng không đạt yêu cầu bảo mật nếu cấu hình sai.

Sau demo, các tài nguyên tính phí như ALB và NAT Gateway cần được dọn dẹp. Việc xóa phải chú ý quan hệ phụ thuộc, đặc biệt NAT Gateway cần xóa hoàn tất trước khi giải phóng Elastic IP và VPC chỉ có thể xóa khi các tài nguyên con đã được xử lý.

B. KỊCH BẢN DEMO BẢO VỆ VÀ THAO TÁC TRIỂN KHAI

1. Giới thiệu

Giới thiệu đề tài và vấn đề HTTP không mã hóa. Trình bày mục tiêu của SecureCloud là kết hợp bảo vệ kênh truyền với kiểm soát truy cập và cô lập hạ tầng. Sau đó nêu kiến trúc ba lớp Internet → Load Balancer → Web Server trong Private Subnet.

2. Trình bày kiến thức tổng quan về Điện toán đám mây và HTTP/HTTPS

Giới thiệu ngắn về Điện toán đám mây và mô hình IaaS được sử dụng trong SecureCloud. Trình bày sự khác nhau giữa HTTP và HTTPS, trong đó HTTPS sử dụng SSL/TLS để bảo mật dữ liệu trên đường truyền. Đây là cơ sở để nhóm xây dựng hệ thống với kiến trúc bảo mật nhiều lớp.

3. Trình bày kiến trúc

Trình bày rõ ALB nằm ở Public Subnet, EC2 nằm ở Private Subnet và không có Public IP. Trình bày Bastion là kênh quản trị. Sau đó giải thích năm lớp bảo mật: VPC/Subnet, Security Group, HTTPS/SSL-TLS, security headers và logging.

4. Kết luận lý thuyết

Qua phần cơ sở lý thuyết, có thể thấy việc bảo mật một website trên môi trường điện toán đám mây không chỉ phụ thuộc vào HTTPS mà cần kết hợp nhiều cơ chế bảo vệ khác nhau. Các kiến thức về Cloud Computing, HTTP/HTTPS, SSL/TLS, VPC, Subnet và Security Group là nền tảng để xây dựng kiến trúc SecureCloud. Từ đó, hệ

thống được thiết kế theo hướng bảo mật nhiều lớp, cô lập Web Server trong Private Subnet và kiểm soát chặt chẽ các luồng truy cập.

5. Thao tác triển khai trực tiếp

- Demo 1: Mở website qua DNS của ALB, chỉ rõ trạng thái HTTP hiện tại và giải thích lý do HTTPS là hướng triển khai tiếp theo.
- Demo 2: Đăng nhập → Dashboard → Đăng xuất; thử truy cập Dashboard khi chưa đăng nhập để minh họa access control.
- Demo 3: Mở EC2 Console và chỉ Public IPv4 = None của web server.
- Demo 4: Mở Security Groups, trình bày ALB SG nhận traffic Internet, Web SG chỉ nhận từ ALB/Bastion và Bastion SG chỉ nhận từ IP quản trị.
- Demo 5: Chạy curl -I và chỉ ra X-Content-Type-Options, X-Frame-Options, Referrer-Policy và Strict-Transport-Security.
- Demo 6: SSH qua Bastion, chạy theo dõi /var/log/nginx/access.log và tạo một truy cập mới để quan sát log.

Các quy trình demo được ghi cụ thể ở trong file DEMO.md trên github

6. Kết quả kiểm thử

Trình bày bảng tổng hợp: website qua ALB, access control, login/logout, không Public IP, SSH qua Bastion, security headers và logging đều đạt. HTTPS end-to-end chưa thực hiện do chưa có domain riêng.

7. Kết luận demo và kiểm thử

SecureCloud đã triển khai kiến trúc bảo mật nhiều lớp gồm VPC/Subnet, Security Group, Web Server trong Private Subnet, Bastion Host, Security Headers và Logging. HTTPS đã được thiết kế triển khai tại ALB nhưng chưa kiểm thử end-to-end do chưa có domain riêng.

C. CÂU HỎI THƯỜNG GẶP KHI BẢO VỆ

1. Vì sao web server không có Public IP mà vẫn phục vụ website?

Vì người dùng kết nối tới ALB trong Public Subnet. ALB chuyển tiếp yêu cầu tới Private IP của EC2 trong nội bộ VPC, do đó người dùng không cần kết nối trực tiếp tới web server.

2. Máy chủ Private Subnet ra Internet bằng cách nào?

Máy chủ có thể chủ động đi Internet qua NAT Gateway. Đây là kết nối outbound; Internet không thể sử dụng NAT để chủ động kết nối ngược vào web server.

3. Vì sao không mở SSH trực tiếp cho web server?

Mở SSH trực tiếp làm tăng bề mặt tấn công. SecureCloud sử dụng Bastion để giới hạn điểm quản trị và Security Group chỉ cho phép SSH từ Bastion tới web server.

4. Security Group khác gì Network ACL?

Security Group có trạng thái và áp dụng theo tài nguyên/instance; Network ACL không có trạng thái và áp dụng theo subnet. Đề tài dùng Security Group làm lớp kiểm soát chính.

5. Không có domain thì có làm HTTPS được không?

Có thể thử bằng chứng chỉ tự ký nhưng trình duyệt không tin cậy. Để triển khai chứng chỉ CA hợp lệ cho website, cần tên miền và quy trình xác minh phù hợp.

6. SSL termination đặt ở đâu và vì sao?

Đặt tại ALB để tập trung quản lý chứng chỉ, đơn giản hóa vận hành và thuận lợi khi có nhiều web server phía sau.

7. Vì sao chọn IaaS?

IaaS cho phép trực tiếp kiểm soát VPC, Subnet, Route, Security Group và EC2, phù hợp mục tiêu học tập và kiểm chứng từng lớp bảo mật.

8. Hệ thống đã hoàn thành HTTPS chưa?

Chưa hoàn thành HTTPS end-to-end trong demo do chưa có domain riêng. Quy trình ACM, HTTPS listener và redirect 301 đã được nghiên cứu và thiết kế.

9. Nếu HTTPS đã mã hóa, tại sao vẫn cần Security Group?

HTTPS chỉ bảo vệ dữ liệu trên đường truyền. Security Group quyết định ai được kết nối tới tài nguyên và cổng nào được mở. Hai cơ chế giải quyết các vấn đề khác nhau.

10. Hướng phát triển quan trọng nhất là gì?

Bổ sung domain và HTTPS thực tế, backend xác thực phía server, database Private Subnet, WAF, CloudWatch và logging tập trung.

D. CÁC LINK WEBSITE LIÊN QUAN ĐẾN DỰ ÁN

1. Github: <https://github.com/Sleepy2608/Cloud-Computing-Project>

2. AWS Console: <https://aws.amazon.com/>